# What is Azure Active Directory?

trimarcsecurity.com/hub-post/what-is-azure-active-directory

Sean Metcalf January 12, 2020

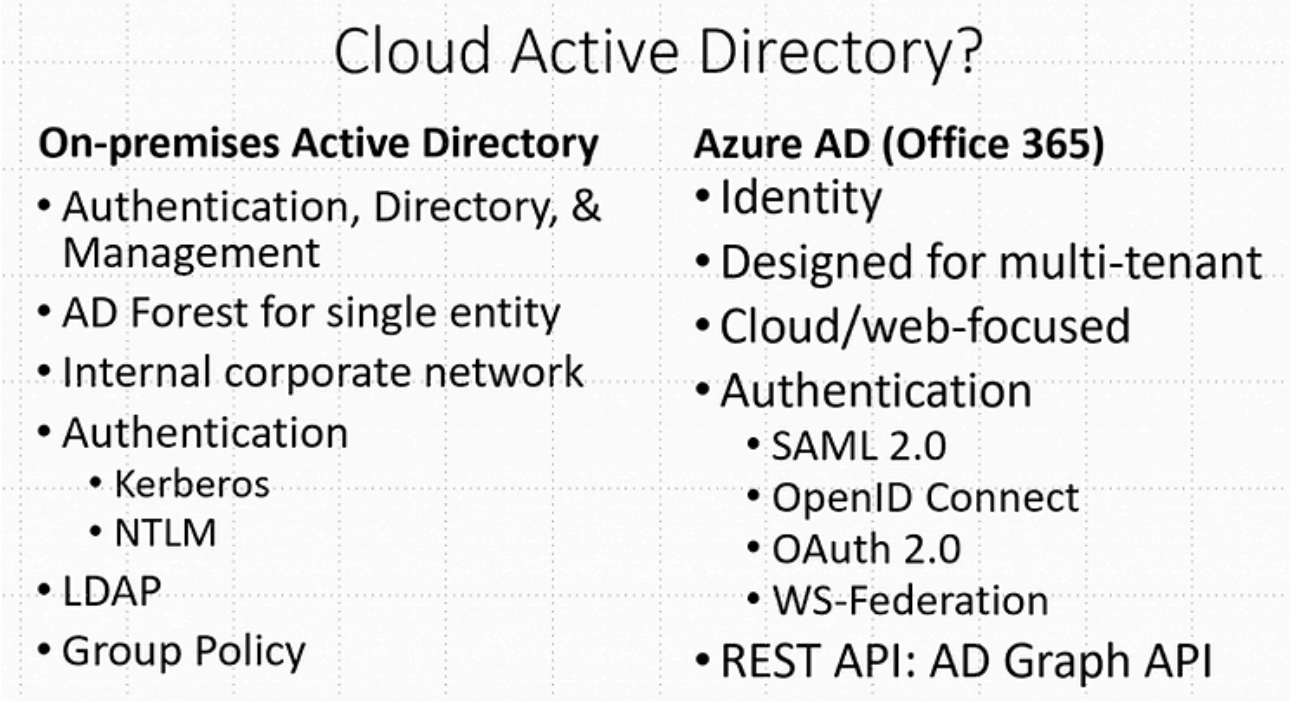
Updated: Dec 13, 2024

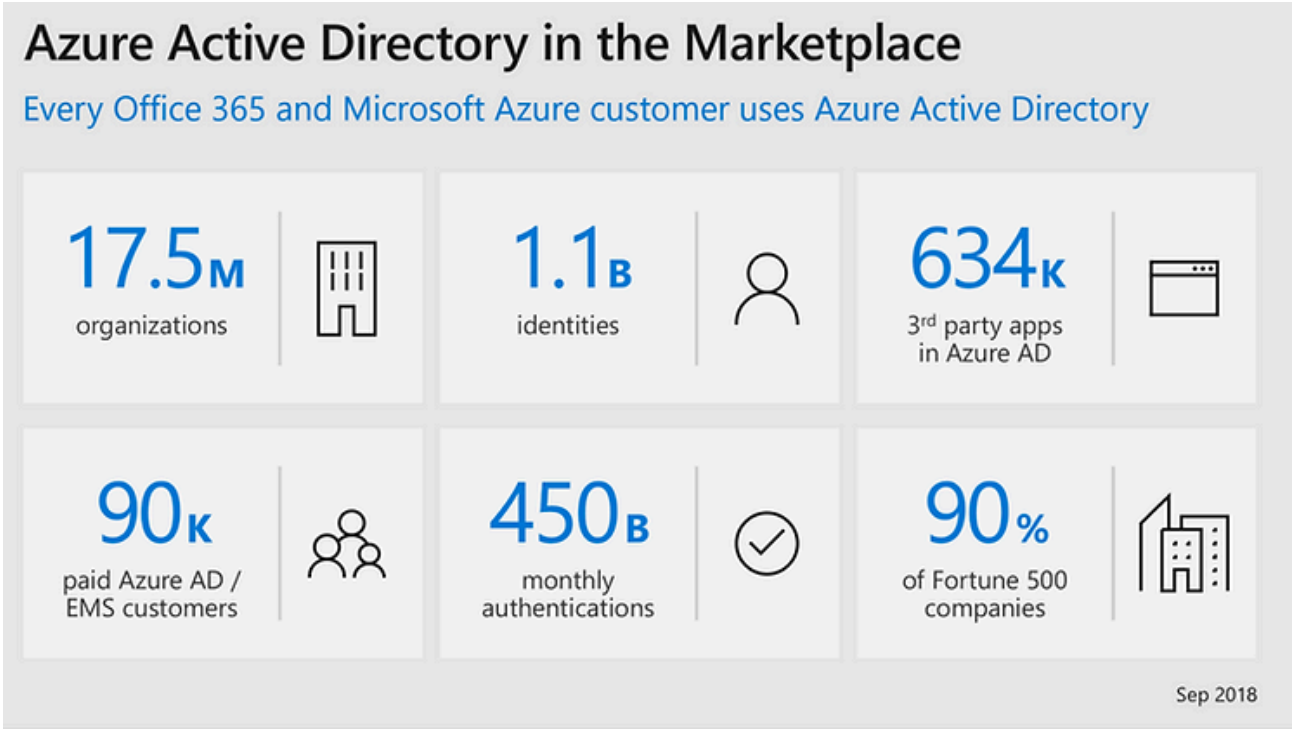
Many are familiar with Active Directory, the on-premises directory and authentication system that is available with Windows Server, but exactly what is Azure Active Directory? Azure Active Directory (Azure AD or AAD) is a multi-tenant cloud directory and authentication service. Azure AD is the directory service that Office 365 (and Azure) leverages for account, groups, and roles. It is also an Identity Provider (IPD) and supports federation (SAML, etc). Note: given how rapidly the cloud changes, elements of this post may become out of date soon after the original post date. **Azure AD is highly available and globally deployed.**

*"Azure AD is deployed in over 30 datacenters around the world leveraging Azure Availability Zones where present. This number is growing rapidly as additional Azure Regions are deployed. For durability, any piece of data written to Azure AD is replicated to at least 4 and up to 13 datacenters depending on your tenant configuration. Within each data center, data is again replicated at least 9 times for durability but also to scale out capacity to serve authentication load. To illustrate—this means that at any point in time, there are at least 36 copies of your directory data available within our service in our smallest region. For durability, writes to Azure AD are not completed until a successful commit to an out of region datacenter. This approach gives us both durability of the data and massive redundancy—multiple network paths and datacenters can serve any given authorization request, and the system automatically and intelligently retries and routes around failures both inside a datacenter and across datacenters.*

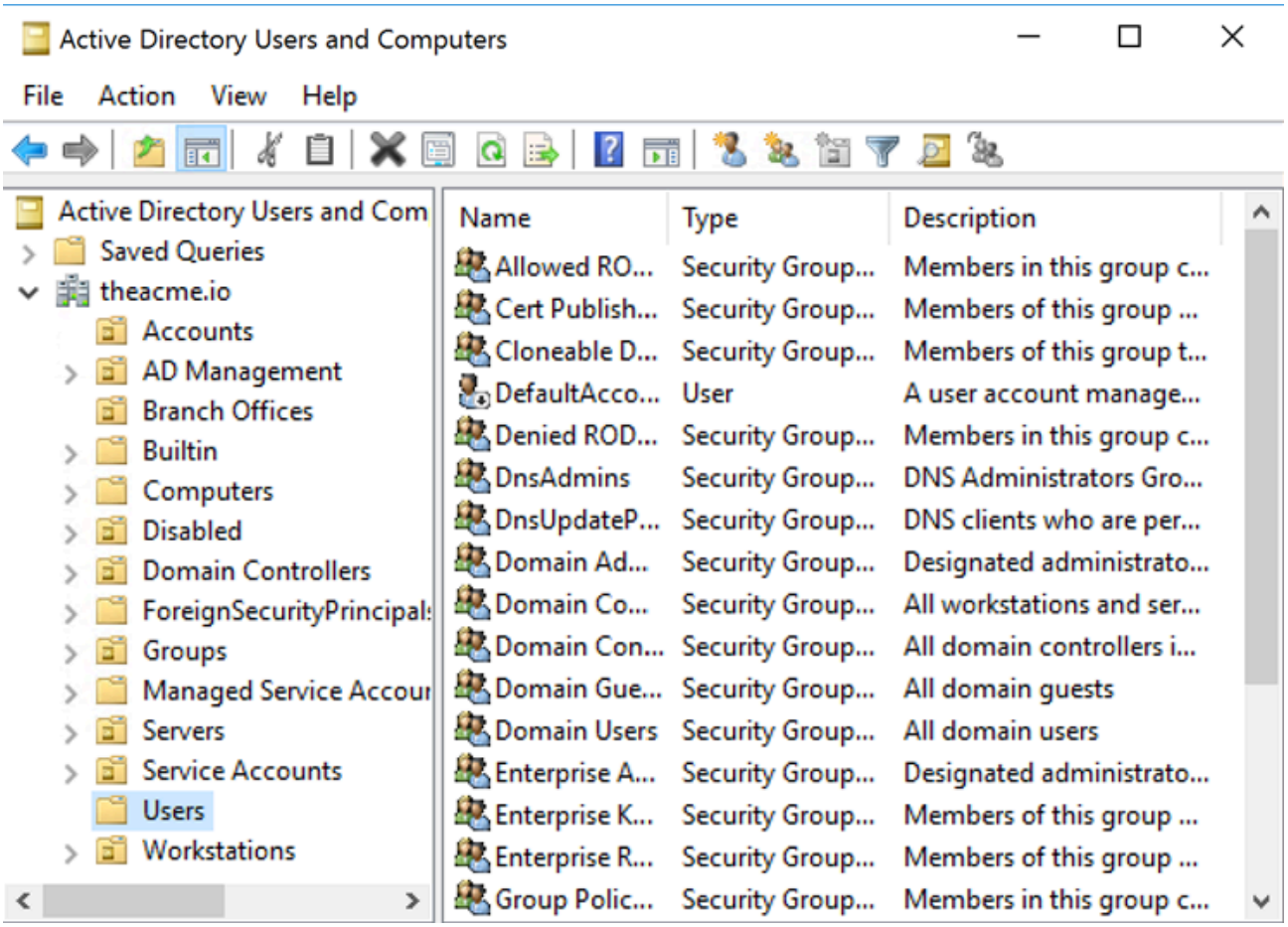
*To validate this, we regularly exercise fault injection and validate the system's resiliency to failure of the system components Azure AD is built on. This extends all the way to taking out entire datacenters on a regular basis to confirm the system can tolerate the loss of a datacenter with zero customer impact. … Azure AD is already a massive system running on over 300,000 CPU Cores and able to rely on the massive scalability of the Azure Cloud to dynamically and rapidly scale up to meet any demand. This can include both natural increases in traffic, such as a 9AM peak in authentications in a given region, but also huge surges in new traffic served by our Azure AD B2C which powers some of the world's largest events and frequently sees rushes of millions of new users. … To support the health checks that gate safe deployment and give our engineering team insight into the health of the systems, Azure AD emits a massive amount of internal telemetry, metrics, and signals used to monitor the health of our systems. At our scale, this is over 11 PetaBytes a week of signals that feed our automated health monitoring systems."*

**Azure Active Directory is Not Cloud AD** Azure Active Directory is not Active Directory hosted in the cloud. There is no standard AD authentication methods such as NTLM or Kerberos; no LDAP; and no group policy (GPO), so Azure AD won't work for traditional on-prem applications. There are cloud hosted Active Directory environments that can be used to manage cloud workloads in Microsoft Azure (Azure Active Directory Domain Services), Amazon AWS (Amazon Managed Microsoft AD), and Google Cloud (Managed Service for Microsoft Active Directory (AD)). These are all hosted Microsoft Active Directory environments which have 2 Domain Controllers (or more) and the tenant admins do not receive Domain Admin rights to the hosted AD environment; only delegated access is provided which often includes the ability to create/manage resources in a specific OU and specific GPOs. *Note: I don't have room to include a comparison of these services here, but may write a future post if there's interest (I did some research comparing Microsoft Azure vs Amazon AWS hosted AD service offerings in 2017).*

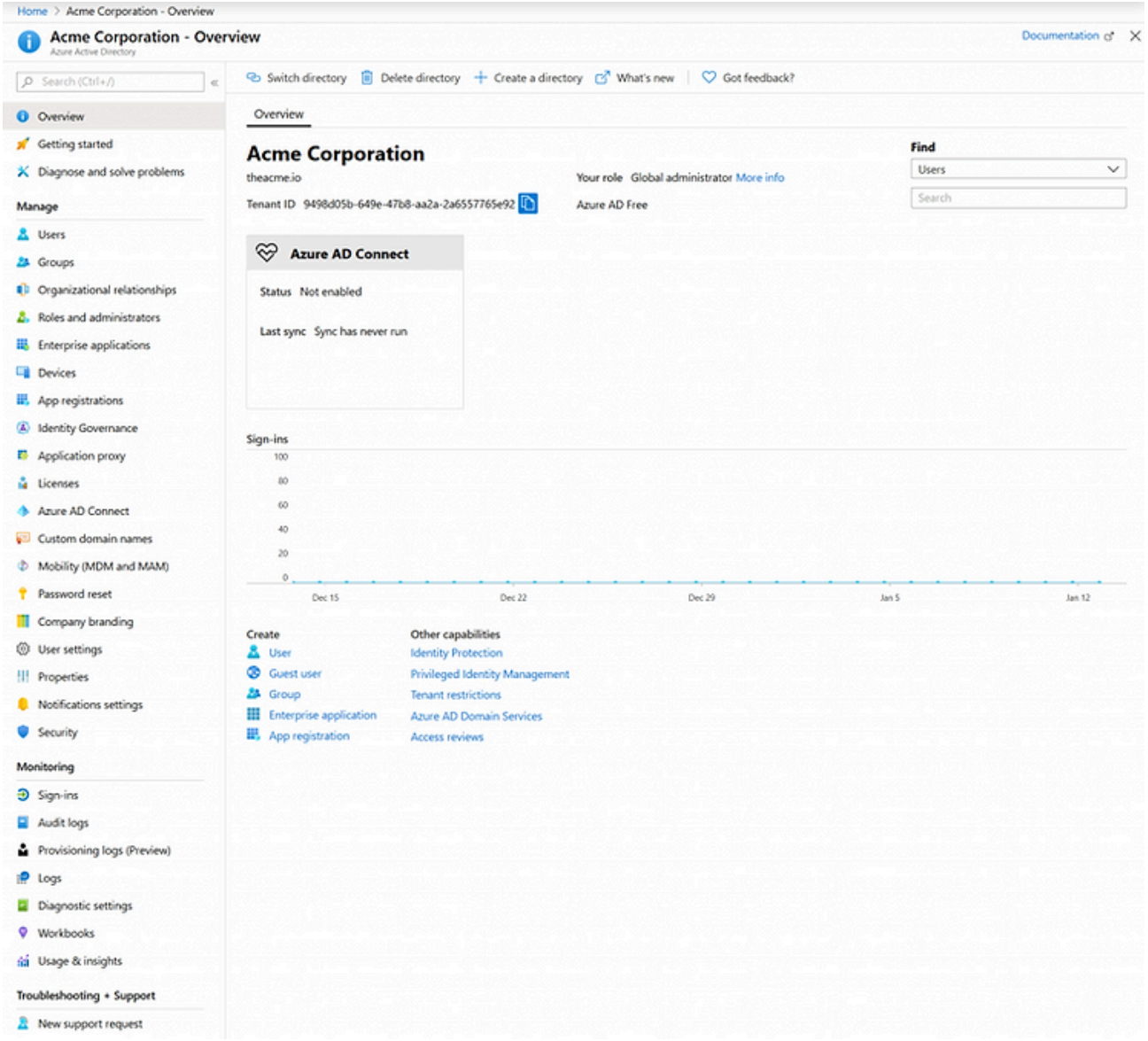





**Primary Management Tools** The tool that most AD administrators are familiar with is Active Directory Users and Computers aka ADUC (MMC tool).




Azure Active Directory administrators will primarily use the web console at https://portal.azure.com to administer the environment.




Admins that manage Active Directory on-prem and now Azure AD/Office 365 will be using the on-prem MMC tools as well as the web admin portals (and various URLs associated with them). There are PowerShell cmdlets available for managing Azure AD (similar to on-prem), though cloud features often move faster than the PowerShell tools are released, which means that using the cloud admin portal should still be used, even when using PowerShell.

### Interfacing with Azure Active Directory

Since Azure AD doesn't have LDAP, interfacing with AAD involves connecting via the Graph API (or PowerShell modules). I like PowerShell, so I use the PowerShell modules (or Portal websites) for management and reporting.

There are 2 primary PowerShell modules for interfacing with Azure AD: MSOnline and AzureAD. These can be installed through the PowerShell install feature:

```
Install-Module -Name MSOnline -Force
Install-Module -Name AzureAD -Force
```

The AzureAD module may eventually replace the MSOnline PowerShell module, but there are features available in MSOnline that haven't been ported to the Azure AD module (yet).

**Azure AD PowerShell Modules & Cmdlets Comparison** (module & cmdlet data as of January 2020)

**Category MSOnline AzureAD**

Application Get-AzureADMSApplication

Application Get-AzureADMSApplicationExtensionProperty

Application Get-AzureADMSApplicationOwner

In the table above, I categorize the cmdlets across the two Azure AD PowerShell module and attempt to link the ones that provide the same or similar capability. I am planning to post more on these cmdlets in the future.

Unfortunately, it isn't a simple matter to single sign-on (SSO) to these modules. A credential can be captured in PowerShell and reused across modules, but only if MFA isn't enforced (which reduces account security). The Microsoft Cloud environment originally only supported username and password authentication. This "legacy authentication" doesn't include Multi-Factor Authentication ("MFA"), so for security reasons, legacy authentication should be disabled (via Security Defaults, Conditional Access, etc). The Azure Active Directory Authentication Library provides "modern authentication" which fully supports MFA (and passwordless!).

ADAL according to Microsoft: *"The Azure Active Directory Authentication Library (ADAL) v1.0 enables application developers to authenticate users to cloud or on-premises Active Directory (AD), and obtain tokens for securing API calls. ADAL makes authentication easier for developers through features such as:*

· *Configurable token cache that stores access tokens and refresh tokens*

· *Automatic token refresh when an access token expires and a refresh token is available*

· *Support for asynchronous method calls"*

There is an ADAL PowerShell Module (Install-Module -Name adal.ps) which provides some level of SSO across modules (that support it). Once you have the ADAL module installed, run the following to load the ADAL token in the session:

```
$clientId = "1b730954-1685-4b74-9bfd-dac224a7b894" # Azure AD PowerShell
$redirectUri = [Uri]::new('urn:ietf:wg:oauth:2.0:oob')
$authority = "https://login.windows.net/common/oauth2/authorize"
$resourceUrl = "https://graph.windows.net"
```

```
$ADALresponse = get-adaltoken -Resource $resourceUrl -ClientId $clientId -
RedirectUri $redirectUri -Authority $authority -PromptBehavior:Always
```

Once the $ADALResponse variable is captured, you can leverage this token in the Azure AD modules:

```
$ConnectAzureADInfo = connect-azuread -AadAccessToken $ADALresponse.AccessToken -
AccountId $ADALresponse.UserInfo.DisplayableId

$ConnectMsolInfo = connect-msolservice -AdGraphAccessToken
$ADALresponse.AccessToken

# Looks like the Microsoft Teams PowerShell module supports ADAL as well, though I
added a new variable that includes the signed-in user UPN.

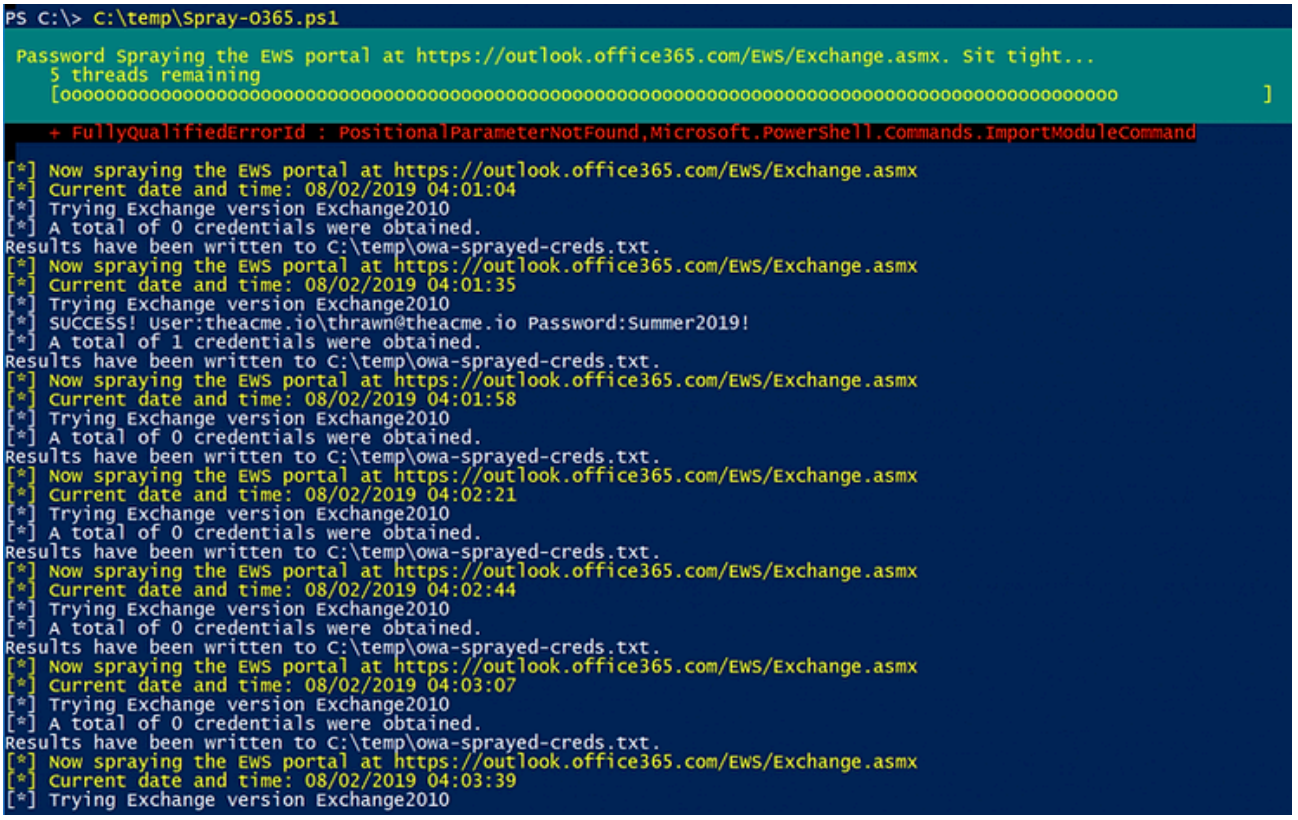
Connect-MicrosoftTeams -AadAccessToken $ADALresponse -AccountId
$AssessmentAccountUPN
```

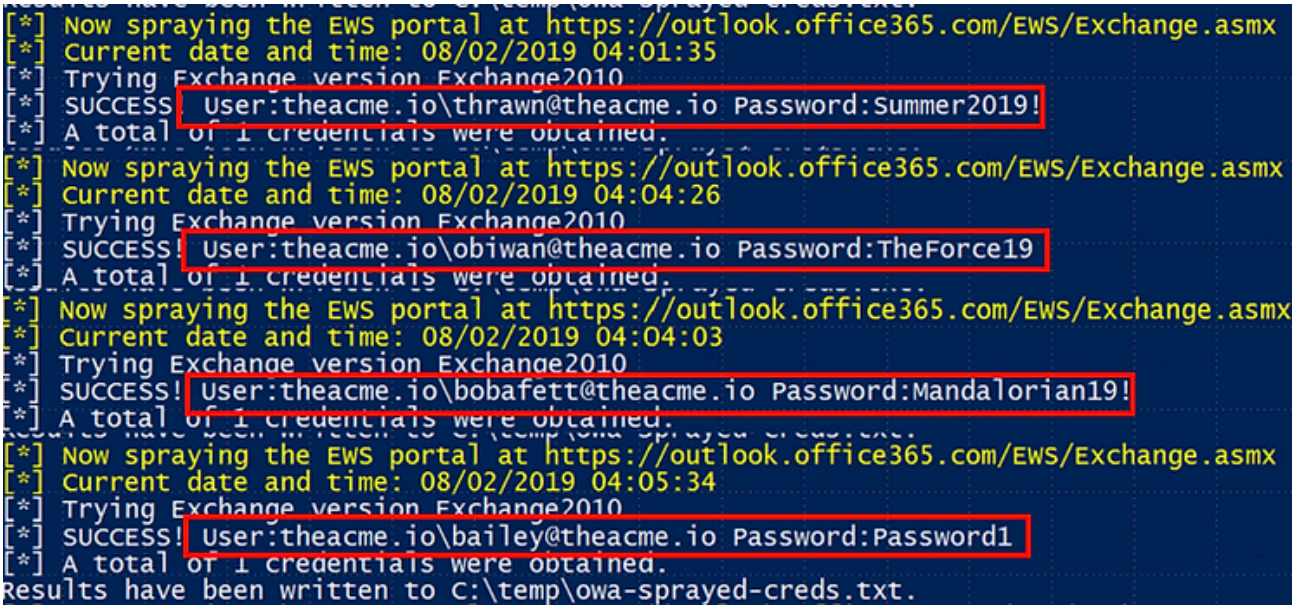
**Access Rights to Azure Active Directory** With Active Directory, just about everything can be viewed as a regular user. Azure AD users can view information about users and groups, but there are some limitations as to what is accessible. In Azure AD, privileged groups are called “roles” (which are groups) in order to identify special access. There are several of these admin roles in Office 365 which provide admin-level rights to all of Office 365 or specific parts of it. (Assigning Roles) Many organizations have a reporting account in the Global Administrator (aka Tenant Administrator) role which is effectively Enterprise Admin, Domain Admin, and Schema Admin wrapped up into a single group. Global Admin has full control to Azure AD and all Office 365 services. This is why many organizations have more than 5 Global Admins (Microsoft’s maximum recommended number). Only cloud accounts should be added to roles so they can leverage Azure MFA (& passwordless) as well as the role membership controlled by PIM. Also strongly recommended is creating a “break-glass” administrator account (or two) to ensure continued privileged access to the tenant. Microsoft published a document on how to secure privileged access. Privileged Identity Management (PIM) is strongly recommended for controlling role membership and requires Azure AD Premium 2 (P2) licenses for each account that will use PIM. PIM provides just in time access to the admin role with the required rights. When an admin needs admin rights, they can request & gain access through PIM (which can be sent for approval or auto-approved). Microsoft recommends all accounts in roles are managed by PIM (and have AAD P2 licenses).There is also a Powershell module for PIM which can be installed: Install-Module -Name Microsoft.Azure.ActiveDirectory.PIM.PSModule In Fall 2019, Microsoft added a new role called “Global Reader” which has read-only/view-only rights to all Azure AD/Office 365 services that Global Admin can see (with some exceptions since Microsoft is still rolling out Global Reader read-only capability to all Office 365 services). Membership in Global Reader should be provided to the security team or auditors that require view-only access to the Microsoft Cloud (Azure AD & Office 365) environment.

**Attacking Azure Active Directory** Office 365 services are accessible from the internet (by default, use Conditional Access to restrict access) which makes them attractive to attackers. Attackers leverage several attack methods against Azure AD & Office 365.

Account Enumeration With old school Active Directory, any Active Directory user can enumerate all user accounts & admin group membership with network access to a Domain Controller. Azure Active Directory users can enumerate all user accounts & admin group membership with access to Office 365 services (the internet by default). User enumeration often possible without an account using O365creeper which attempts to authenticate to O365 using a list of email addresses. Based on the response code, the tool determines if the email address is a valid user account (or not). Azure AD Enumeration Tools O365 Creeper – Office 365 Authentication Page (Python) [Account Discovery] OWA (Golang) ActiveSync (Python) MSOnline/AzureAD PowerShell Module (PowerShell)

Password Spraying A common method attackers leverage as well as many penetration testers and Red Teamers is called “password spraying”. Password spraying is interesting because it’s automated password guessing. This automated password guessing against all users typically avoids account lockout since the logon attempts with a specific password are performed against against every user and not one specific one which is what account lockout was designed to defeat. The attacker starts with a list list of passwords they’re going to try which starts with the most likely passwords (“Fall2017”, “Winter2018”, etc). When password spraying begins, we start with the first password in the list. That first password is used in an attempt to authenticate as every user (or a subset). This one password is attempted against each user and once all users have been tested with that password, we move on to the next one.



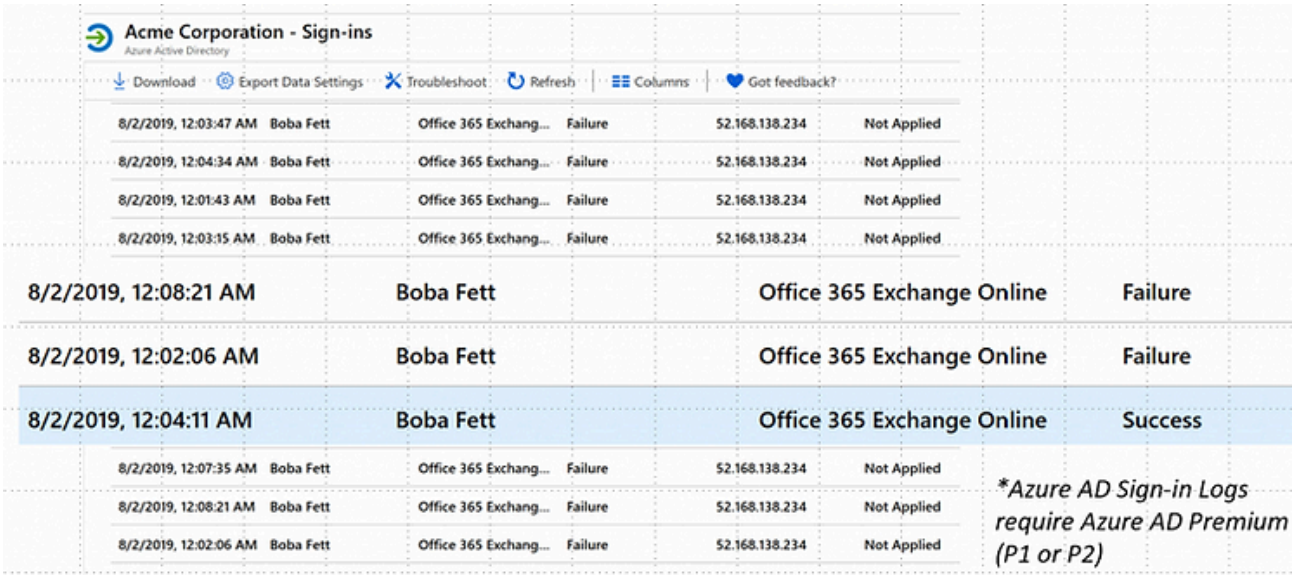

Password Spraying is relatively trivial to perform and is extremely effective. We have worked with many organizations with accounts that were compromised by password spraying their cloud environment. Many customers that are Federated don't realize it's their job to look for this, not the cloud's. There is a real risk beyond the cloud with password spraying. If the same password is used for the cloud account and on-prem and there is no MFA configured, it's possible that an attacker could password spray the cloud account and then gain access to the corporate network. This is not a theoretical or hypothetical scenario and underscores the importance of MFA.

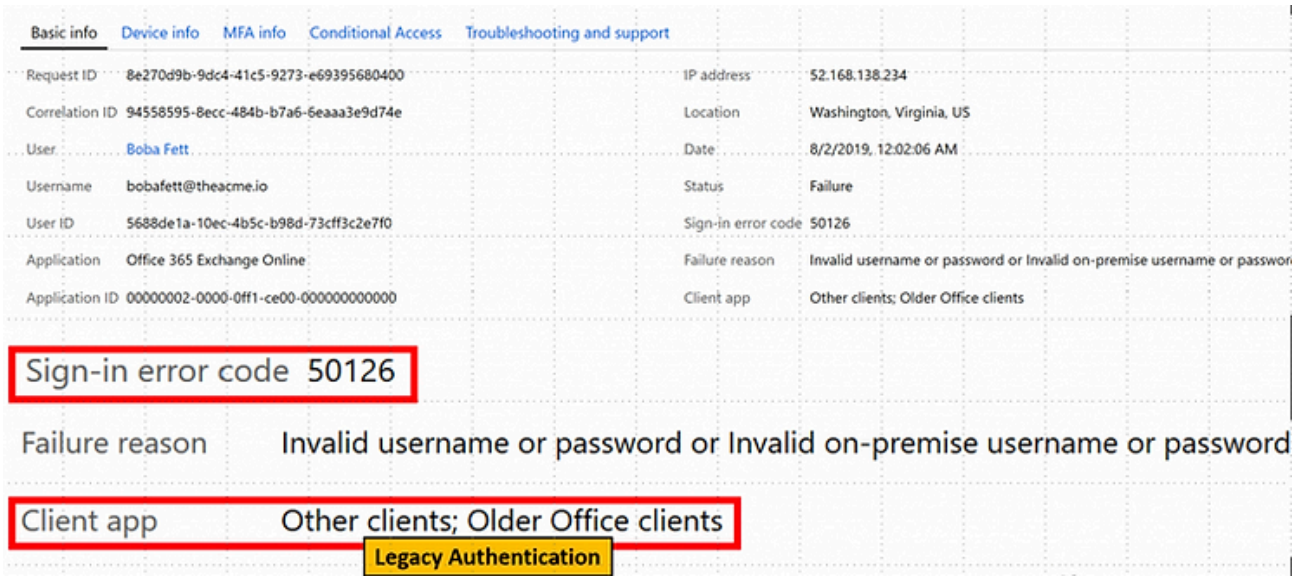
Office 365 Password Spraying Tools Ruler (Exchange) [Golang] SprayingToolkit (Lync/Skype for Business/OWA) [Python] LyncSniper (Lync/Skype for Business)

[PowerShell] MailSniper (OWA/EWS) [PowerShell]

Office 365 Password Spraying Mitigation Disable Legacy authentication by enabling "Security Defaults" or configuring a custom Conditional Access policy. Also requiring MFA for all users is strongly recommended.

Office 365 Password Spraying Detection Assuming password spraying targets Office 365 services and federation is not configured (ADFS, Okta, etc), then detection can be performed by referencing the Azure AD sign-in logs.




Detect by correlating multiple events for the same user within a timeframe with the sign-in error code "50126" and the Client app is "Other clients; Older Office clients" (which means legacy authentication was performed).

Account token theft & reuse Since cloud authentication typically results in a token stored in the authenticated app or web browser, this is the proof of authentication and could be reused. The web browser typically stores this auth token as a cookie. If this data is stolen,

an attacker could leverage this to spoof access and configure persistence for continued access.

Microsoft's Azure AD GitHub includes PowerShell code for reviewing Azure AD configuration (https://github.com/AzureAD/AzureADAssessment) Trimarc also has a new service offering called the Microsoft Cloud Security Assessment (MCSA) which is similar to the on-prem Active Directory Security Assessment but focused on Azure AD & Office 365.

**Additional Office 365 Service PowerShell Modules** Exchange Online Module Install-Module -Name ExchangeOnlineManagement

Microsoft SharePoint Install-Module -Name Microsoft.Online.SharePoint.PowerShell

Microsoft Teams Install-Module -Name MicrosoftTeams

Install-Module -Name Microsoft.Graph.Intune -Force (Requires an admin to provide Admin Consent: Connect-MSGraph -AdminConsent)

**References:**

*Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.*